MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Controlling Application Usage with App-ID

Unit 8 · Information Security 2 (10-151-111)

MID-STATE TECHNICAL COLLEGE

Learning Outcomes

By the end of this unit, you will be able to:



Describe basic App-ID

Explain how signatures, decoders, and heuristics identify applications.



Detect types of applications

Read App-ID labels and research any application in the database.



Configure application control

Build application groups and filters and use them in Security policy.



Monitor application control events

Filter the Traffic log by application, rule, and action.



Troubleshoot application control issues

Fix shadowed rules, missing dependencies, and unknown traffic.

LESSON 1

App-ID Fundamentals



What Is an Application?

- An **application** is a specific program or feature whose communication can be labeled, monitored, and controlled.
- Applications arrive through a **web browser**, a **client-server** model, or a **peer-to-peer** design.
- Some are business tools you must allow; others are entertainment or personal services you may want to block.
- One port can carry many applications, so `tcp/443` tells you almost nothing about what is in the session.



App-ID

The firewall engine that names the application inside every session, so policy can be written around **what** is running instead of which port it uses.

Port-Based vs. App-ID Rules

Traditional firewall: allow port 53

- DNS on port 53: allowed
- BitTorrent on port 53: allowed
- Unknown command-and-control on port 53: allowed
- The log only says "port 53 allowed"

App-ID: allow `dns` on application-default

- DNS on port 53: allowed
- BitTorrent on port 53: denied, it is not DNS
- Unknown traffic on port 53: denied, it is not DNS
- The log names every application seen

Blocklists lose to zero-days: an IPS rule that blocks BitTorrent cannot block malware it has never seen. A rule that allows only DNS blocks it anyway.

How App-ID Identifies Traffic

App-ID applies several techniques in turn until one of them names the application:

Technique	What it looks at
Application signatures	Patterns in the payload that match an entry in the App-ID database
SSL decryption	If a Decryption policy applies, decrypts the session so signatures can see inside
Protocol decoders	Follows a protocol such as HTTP to find applications tunneled inside it
Behavioral heuristics	How the traffic behaves, for evasive apps that hide their payload

If nothing matches, the traffic is labeled unknown-tcp, unknown-udp, or unknown-p2p, and Security policy still decides what happens to it.

Identifying Encrypted Applications

- Encryption hides the payload, so **signatures and decoders** cannot see the application.
- With **decryption** configured, App-ID identifies the application in the decrypted session as normal.
- Without it, App-ID uses the certificate **Common Name (CN)** when one site owns the IP address.
- When many sites share one IP, it uses the TLS **Server Name Indication (SNI)** field instead.



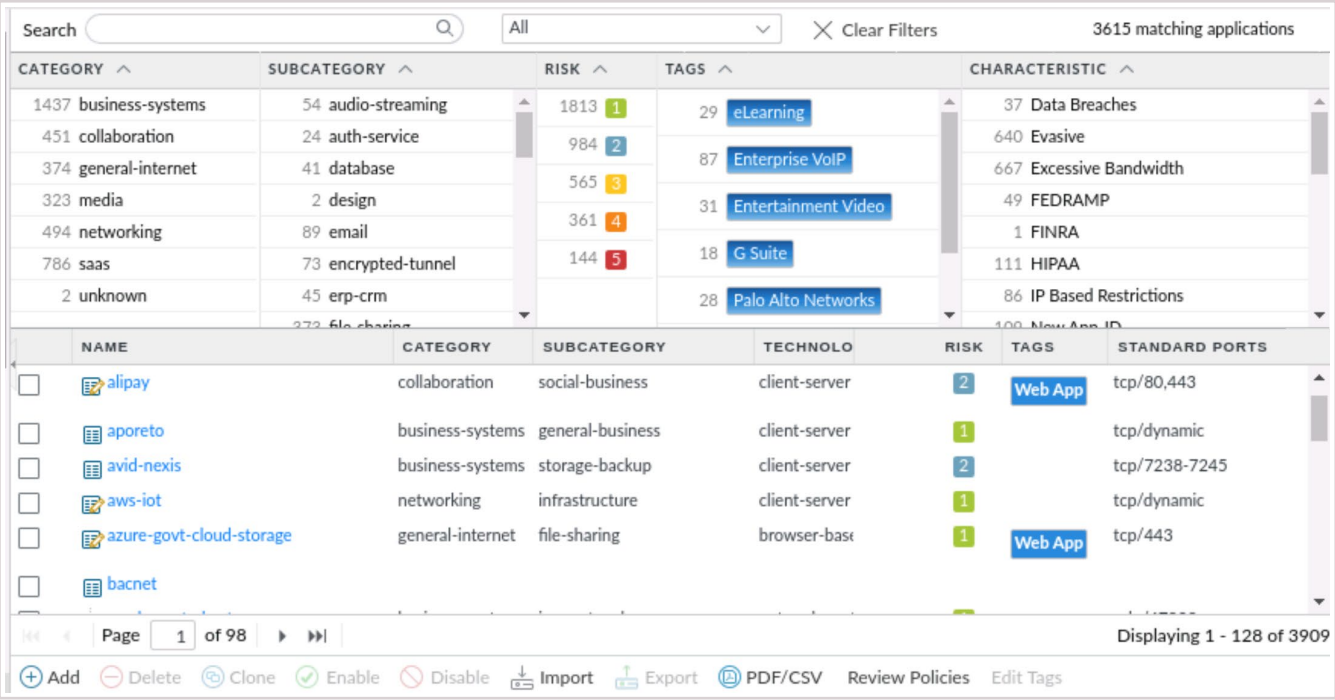
SECURITY FOCUS

Attackers know most firewalls cannot see inside TLS, so malware and data theft increasingly ride over port 443.

Why it matters: If you never decrypt, "ssl" in the log may be the only thing you ever learn about that traffic.

The App-ID Database

Objects > Applications lists every application App-ID can identify, with filters for each attribute:



- **Category** and **subcategory** group applications by purpose.
- **Risk** runs from 1 (lowest) to 5 (highest).
- **Characteristics** flag behaviors such as evasive or prone to misuse.
- Public copy: `applipedia.paloaltonetworks.com`



LESSON 2

Detecting and Labeling Applications

TCP Takes Several Packets, UDP Takes One

TCP

- SYN, SYN/ACK, and ACK carry **no application data**
- App-ID waits for the first request, such as an HTTP `GET`
- May need the fourth or fifth packet before it can name the app

UDP

- No handshake: data rides in the first packet
- App-ID can usually identify `dns` from a single packet
- Fewer labels, because there is no handshake to fail

Why it matters for policy: the firewall must allow the handshake before it knows the application, so the first few TCP packets are judged on zone, address, and port.

Reading App-ID Labels

When App-ID cannot name an application, it still writes one of these labels to the log:

Label	Protocol	Meaning
not-applicable	TCP, UDP	Dropped by Security policy before an application was identified
incomplete	TCP	Handshake never finished, or finished with no data after it
insufficient-data	TCP	Handshake finished but not enough payload to identify the application
unknown-tcp / -udp	TCP, UDP	Enough data, but nothing in the App-ID database matched
unknown-p2p	TCP, UDP	Looks like peer-to-peer but matches no known peer-to-peer app

Known applications appear by name, such as dns, ssl, or gmail-base.

Application Shifts

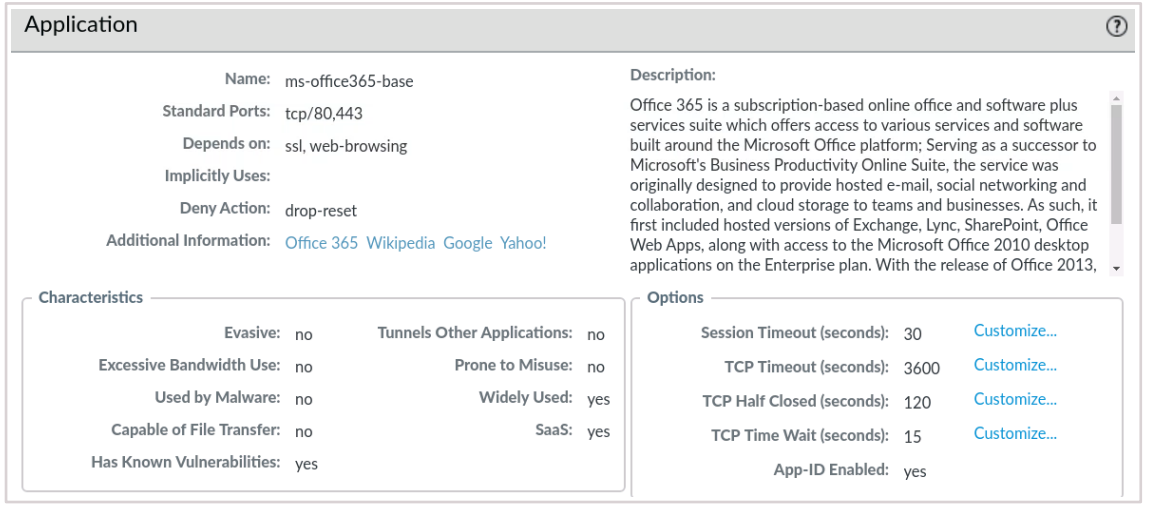
App-ID refines its answer as more packets arrive in the same session:

```
insufficient-data  >  web-browsing  >  generic-app-base  >  generic-app-chat
```

- Each change is an **application shift**, and the firewall checks Security policy again each time.
- A session allowed as `web-browsing` can be blocked once it shifts to an application you did not allow.
- This is how a rule can allow `slack-base` and still block Slack file transfer.

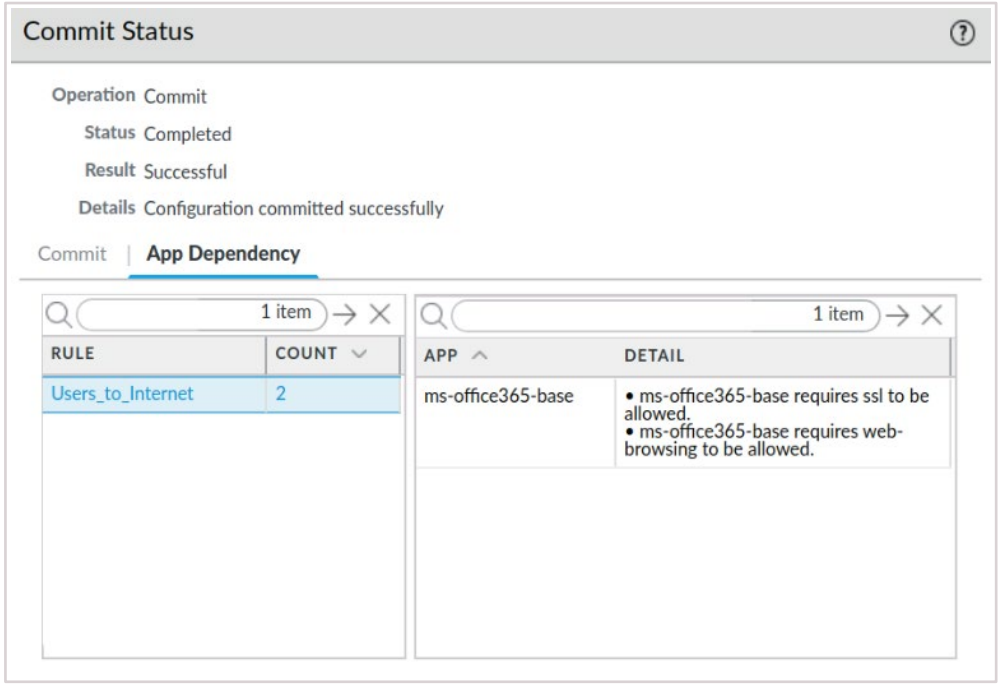
Dependencies and Implicit Applications

- **Depends on**: other applications that must also be allowed, or this one breaks.
- **Implicitly uses**: parent applications that are allowed automatically.
- `facebook-base` implicitly allows `web-browsing` and `ssl`.
- `facebook-chat` still depends on `facebook-base`, so add it explicitly.



Unresolved Dependencies at Commit

- Every commit checks whether each rule's dependencies are allowed by **some** rule.
- Missing ones appear on the **App Dependency** tab of the commit window, per rule.
- Click the rule's **Count** to see what is missing, then the rule name to edit it.
- When adding applications, select the **Depends On** column and click **Add to Current Rule**.



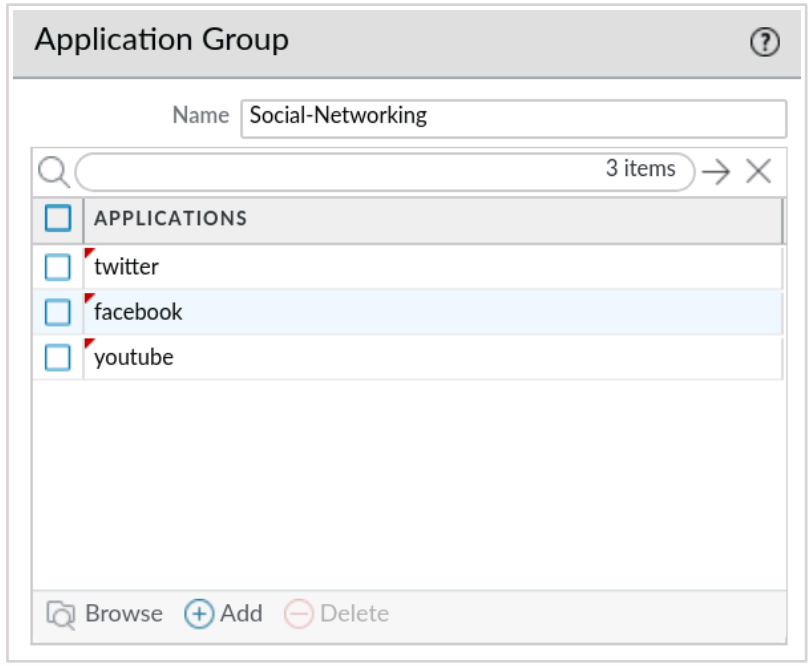
LESSON 3

Configuring Application Control



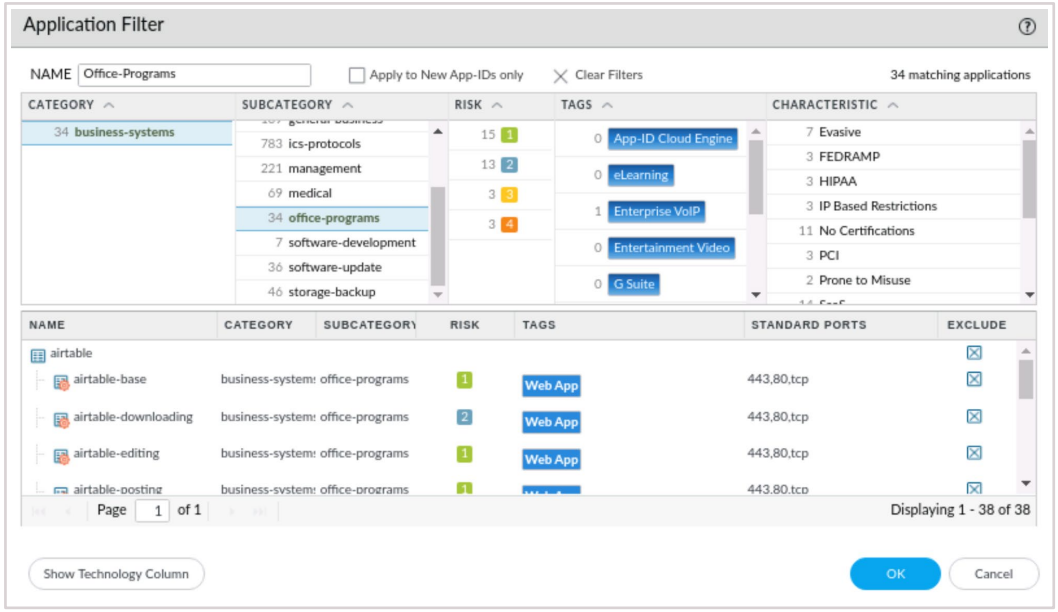
Application Groups

- An **application group** is a static, named list of applications you choose.
- Use one group in many rules instead of repeating the same list.
- Groups can hold applications, application filters, and other groups.
- Lab: `paloalto-apps` holds the update and cloud apps the firewall itself uses.



Objects > Application Groups > Add

Application Filters and Tags



- An **application filter** matches applications by attribute: category, subcategory, risk, tags, characteristics.
- **Dynamic**: new applications that match are included after each content update.
- Palo Alto Networks **tags** (such as Enterprise VoIP) are kept current for you; add custom tags of your own.
- Use a tag inside a filter, then the filter in a rule.

The Service Setting Matters

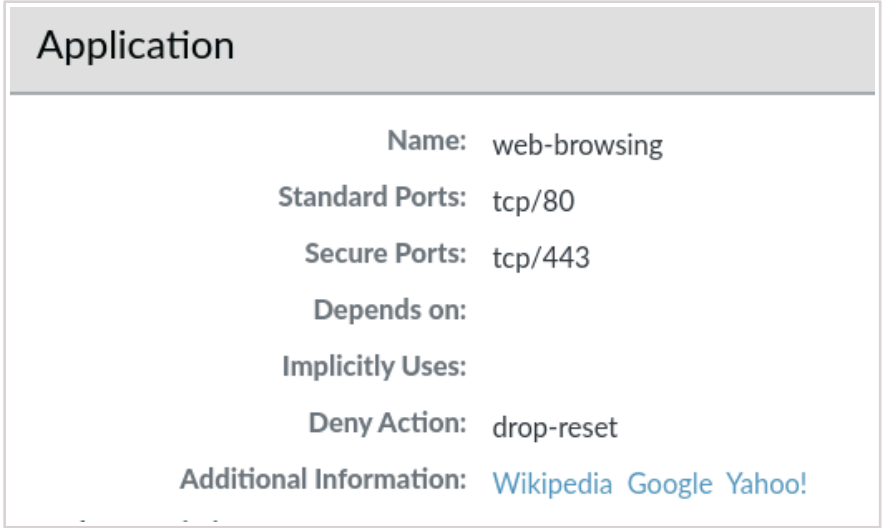
The Application tab says what is allowed; the Service tab says on which ports:

Service	Matches	Use it for
application-default	The application on its standard ports only	Every allow rule
any	The application on any port	Block rules, such as ssh on every port
Custom service	The application on a port you define	mysql on a non-standard port

Policy Optimizer will not do this for you: rules it creates keep their old service, so change them to application-default before you commit.

application-default on Secure Ports

- For cleartext sessions, application-default matches the **Standard Ports**.
- For SSL sessions, it matches the **Secure Ports**.
- Supported for `web-browsing`, `smtp`, `ftp`, `ldap`, `pop3`, and `imap`.



Handling Unknown Applications

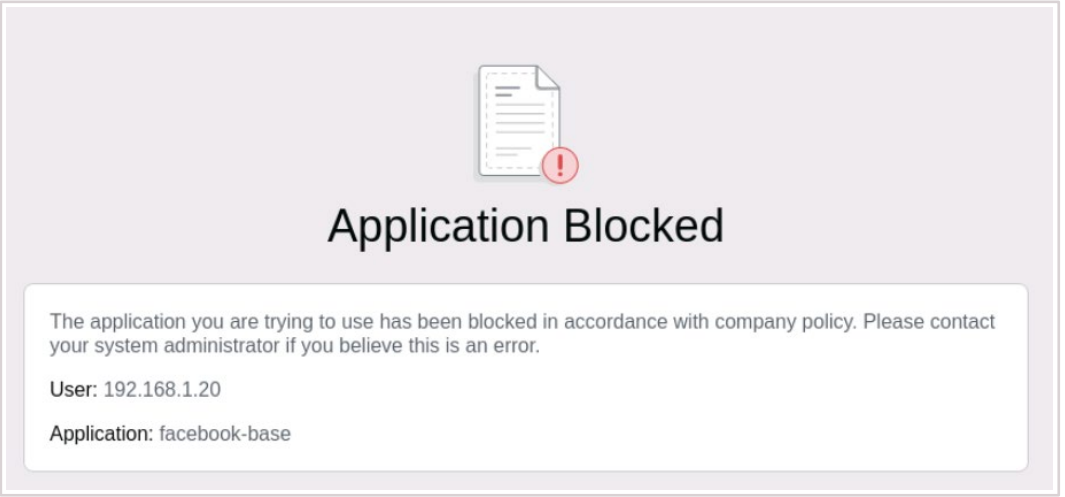
Three ways to deal with traffic labeled unknown-tcp, unknown-udp, or unknown-p2p:

Method	Where	Trade-off
Block unknown traffic	Policies > Security	May also block a legitimate internal app
Custom application	Objects > Applications > Add	Names the app and keeps inspection on
Application Override	Policies > Application Override	Skips App-ID and threat inspection

Find out what it is first: goal is no unknown applications inbound or outbound. Investigate before you allow, override, or block.

The Application Block Page

- Tells users the firewall **blocked** a web application, instead of a timeout.
- Enable it under **Device > Response Pages**. It is off by default.
- Response pages must also be enabled on the **Interface Management Profile**.
- It cannot appear in an **HTTPS** session unless decryption is configured.



LESSON 4

Monitoring and Troubleshooting



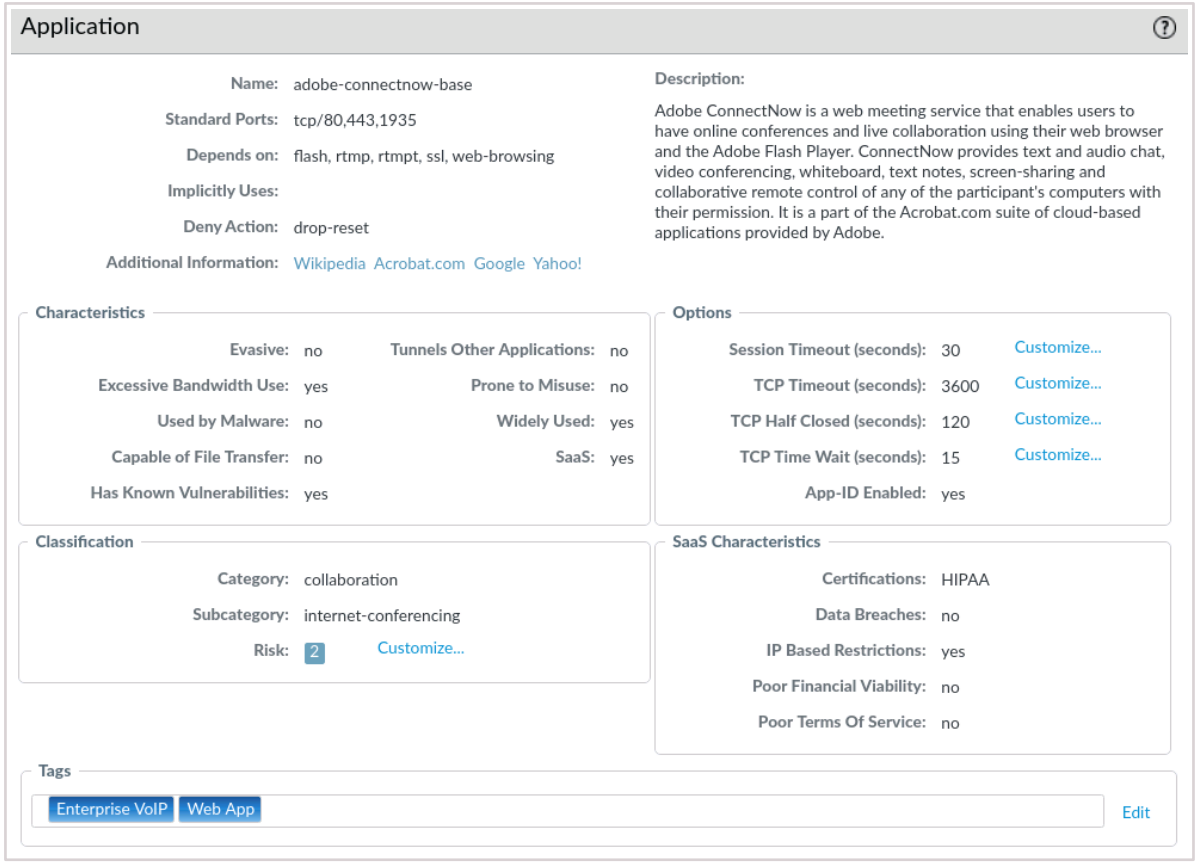
Monitoring Applications in the Traffic Log

Monitor > Logs > Traffic: the Application column shows what App-ID decided for each session.

```
( app eq paloalto-updates )
( addr.src in 192.168.1.20 ) and ( app neq dns )
( action neq allow )
```

- One application, and the **rule** that handled it.
- Everything one client did, minus DNS noise.
- Everything the firewall **blocked**. Look for interzone-default in the Rule column.

Researching an Application



- Click the application name in any log, or search **Objects > Applications**.
- Check **category**, **risk**, and **standard ports**.
- Read the **characteristics**: evasive, prone to misuse, transfers files.
- Decide: does the business need it on this network?

Rule Shadowing

- Rules are evaluated **top down**; the first match wins.
- A broad rule above a specific one **shadows** it, so the specific rule never matches.
- After a commit, the **Rule Shadow** tab lists the shadowing and shadowed rules.
- Missed it? Open **Tasks**, select the last Commit, and check the tab there.

SECURITY FOCUS

A rule with Application set to any above your application rules quietly makes them decoration. The policy looks strict but behaves like a port-based firewall.

Why it matters: You think you are enforcing App-ID when you are not.

Troubleshooting Application Control

Symptom	Likely cause	Where to look
Traffic hits the wrong rule	Rule shadowing	Commit > Rule Shadow tab; reorder rules
Allowed app still breaks	Missing dependency	Commit > App Dependency tab; Depends on
Log shows unknown-tcp	No signature matches	Investigate; custom app or block
No block page appears	Disabled, or HTTPS	Response Pages; Interface Mgmt Profile
Rule changes after an update	New or modified App-ID	Dynamic Updates > Review Policies

Start every investigation in the Traffic log: Application, Action, and Rule columns together tell you most of the story.



LESSON 5

Migrating and Maintaining App-ID Policy

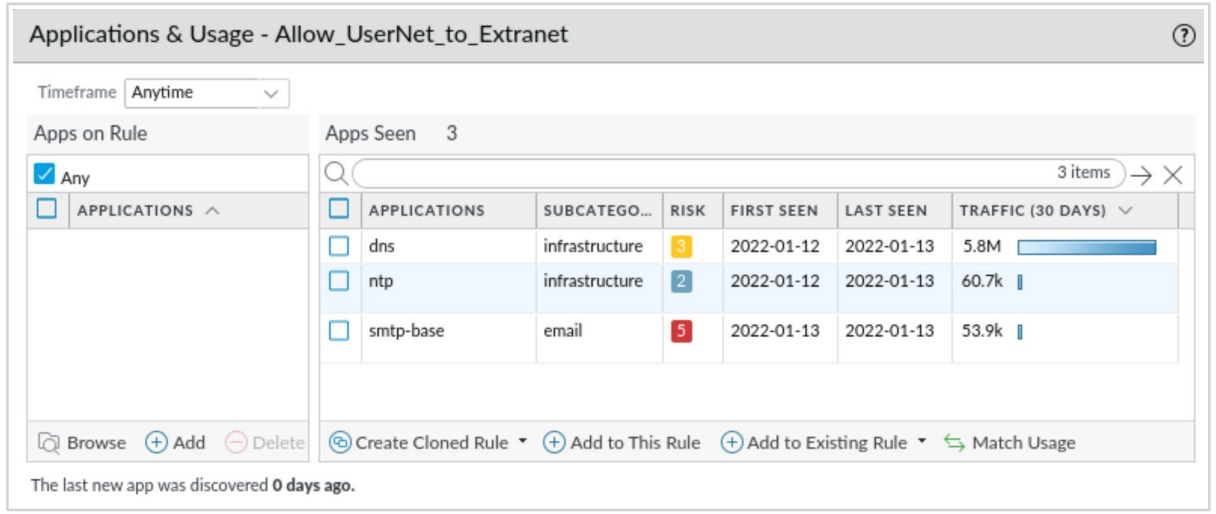
Moving to Application-Based Policy

Policy Optimizer > Rules Without App Controls lists every rule whose Application is any.

Phase	Timing	What happens
1. Migrate	~30 days	Move the old policy like-for-like, cut over, and let the firewall log apps per rule
2. Convert	After 30 days	Build application-based rules above the port-based rules using Apps Seen
3. Remove	60 to 90 days	Disable port-based rules with zero new hits, then delete them

The target: at least 80 percent application-based rules, and no unknown applications in or out of the network.

Four Ways to Convert a Rule

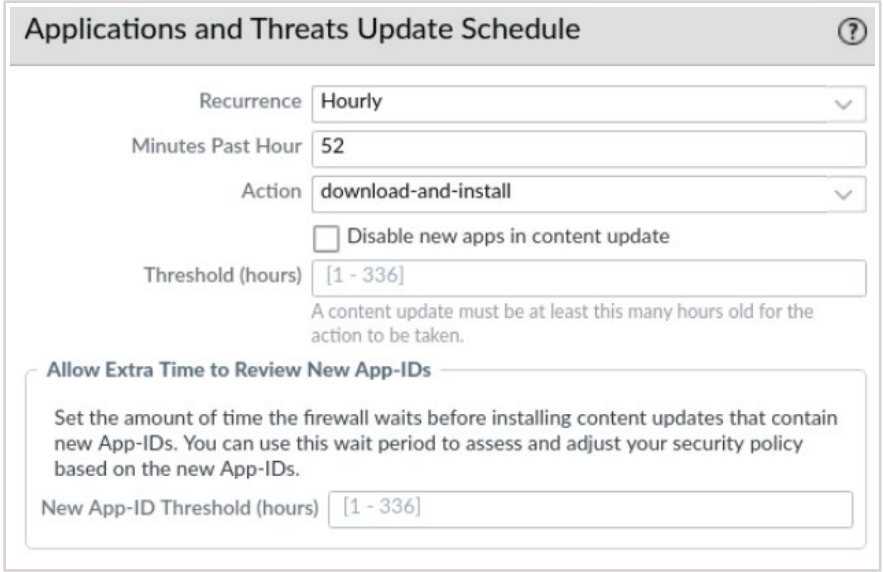


Option	Effect
Create Cloned Rule	New rule above; safest
Add to This Rule	Replaces the old rule
Add to Existing Rule	Adds to another rule
Match Usage	Copies every app seen

Every option keeps the old Service value. Set application-default yourself, then commit.

Keeping App-ID Current

- New and changed applications arrive in **Applications and Threats** content updates.
- If App-ID cannot identify traffic, **Content-ID** cannot inspect it either.
- Schedule **download-and-install** under Device > Dynamic Updates.
- Option: **disable new apps** in the update so they do not change enforcement until reviewed.



Review Before You Trust an Update

Review Apps

- Lists new and modified App-IDs in a release
- Check **Depends on** and **Previously Identified As**
- Read the content release notes as well

Review Policies

- Shows which rules a new App-ID would affect
- Compares against the candidate configuration
- Add the new app to a rule before it goes live

Quiet failures: an update that renames how traffic is identified can make an allow rule stop matching. Users notice before the logs do.

Security Focus: Positive Enforcement

SECURITY FOCUS

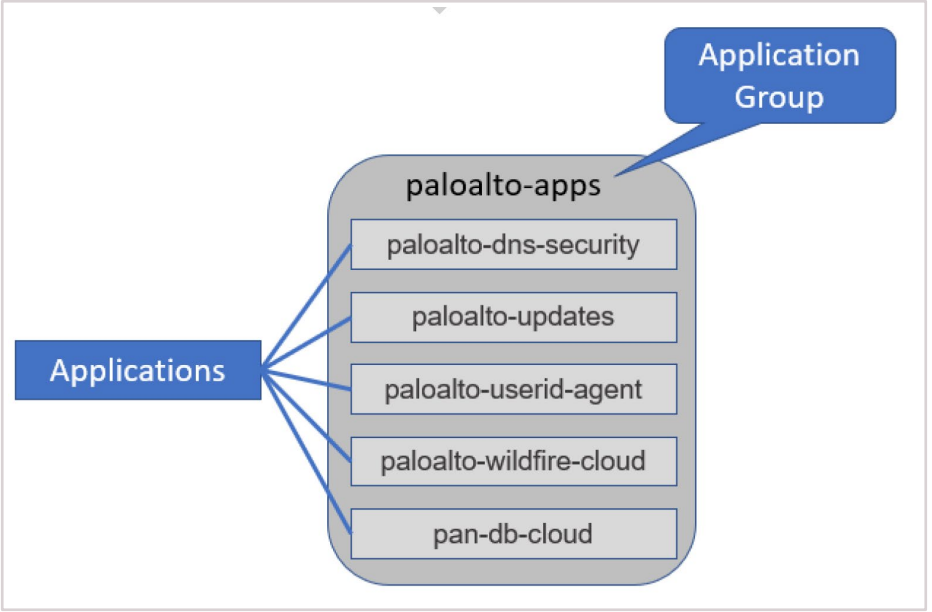
Allow only the applications the business needs, on **application-default** ports, and let the deny rule handle everything else. Do not leave a rule with Application set to **any** above your application rules, and do not let unknown traffic cross the perimeter unexamined.

Why it matters: Every application you do not allow is an attack path that no longer exists, including the ones nobody has discovered yet.

Hands-On Lab 7: Controlling Application Usage with App-ID

NETLAB+ · PANv11 Firewall Essentials Lab 7 · baseline edu-210-11.0a-07.xml

- Build the `paloalto-apps` group and the Allow-PANW-Apps rule.
- Find why update traffic misses the rule, and fix it.
- Research an application in the App-ID database.
- Restrict Users_to_Extranet and Users_to_Internet to named apps.
- Enable and test the Application Block Page.



Lab 7 Tips

- **The shadow is on purpose.** Allow-PANW-Apps lands below Users_to_Internet; moving it to position 3 is the fix.
- **Pick one section.** High-Level runs 1.1 to 1.17; Detailed runs 2.1 to 2.13 with the commits folded in.
- **Your Depends On list may be longer** than the screenshot. Select all of it.
- **Test the block page with http in Firefox.** Chrome upgrades to HTTPS, and the page cannot appear there.

Unit 8 Homework

Always check Blackboard for assignments and due dates.



- Unit 8 Lab: NETLAB+ Lab 7, Controlling Application Usage with App-ID
- Unit 8 PAN App Control Video Worksheet
- Unit 8 Quiz

Key Takeaways

- App-ID names the application with signatures, decoders, and heuristics, not the port.
- Labels like incomplete and unknown-tcp tell you why an application was not named.
- Use groups and filters in allow rules, with application-default as the service.
- Filter the Traffic log by app, rule, and action to see what is really happening.
- Check rule shadowing and dependencies first, and keep App-ID content current.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 8 · Controlling Application Usage with App-ID

MID-STATE TECHNICAL COLLEGE